

(d) MAPEO DETALLADO: PREGUNTAS DE ENCUESTA A REQUISITOS NORMATIVOS

Trazabilidad Completa: Encuesta Integral – NIS2 / CRA / ISO 27001 / GDPR

Versión: 1.0

Fecha: Enero 21, 2026

Alcance: 68 preguntas mapeadas a requisitos regulatorios España 2026

Formato: Tablas Markdown con referencias directas a normativa

INTRODUCCIÓN

Este documento proporciona **trazabilidad exhaustiva** desde cada pregunta de la "Encuesta Integral de Ciberseguridad Organizacional" hasta requisitos específicos de:

-  NIS2 (Directiva UE 2022/2555): Medidas mínimas operador esencial
-  CRA (Cyber Resilience Act): Requisitos fabricantes digitales
-  ISO 27001:2022: 93 controles Anexo A
-  GDPR (Reglamento UE 2016/679): Artículos 5, 25, 28, 32-34
-  ENS (Esquema Nacional Seguridad): Niveles básico/medio/alto

MAPEO SECCIÓN 1: GOBERNANZA Y ESTRATEGIA

Tabla 1.1: Preguntas Gobernanza → Requisitos Normativos

# Pregunta	Pregunta Encuesta	NIS2	CRA	ISO 27001	GDPR	ENS	Criticidad
P1.1	¿Existe política formal de ciberseguridad aprobada por dirección?	Med. 1	Anexo I	5.1	Art. 5	3.1	● CRÍTICA
P1.2	¿Se asignan roles y responsabilidades específicas (CISO, owner datos)?	Med. 1	Anexo I	5.1-5.3	Art. 5	3.1	● CRÍTICA
P1.3	¿Se realiza revisión anual de la política de ciberseguridad?	Med. 9	Anexo I.5	5.1	Art. 32	5.1	● ALTA
P1.4	¿Existe comité o steering committee de ciberseguridad?	Med. 1	Anexo I.3	5.1	Art. 5	3.1	● CRÍTICA
P1.5	¿Se mapean requisitos normativos aplicables a tu sector/región?	Med. 1	Anexo I	5.1	Art. 5	3.1	● CRÍTICA

Patrón Compliance: Para cumplir NIS2 Med. 1, TODAS las preguntas P1.1-P1.5 deben responder SÍ.

Tabla 1.2: Preguntas Presupuesto & Inversión

# Pregunta	Pregunta Encuesta	NIS2	CRA	ISO 27001	GDPR	Criticidad
P1.6	¿Existe presupuesto dedicado y separado para ciberseguridad?	Med. 1	Anexo I.6	8.1	Art. 5	● ALTA
P1.7	¿Se revisa y actualiza presupuesto anualmente según amenazas emergentes?	Med. 9	Anexo I.6	8.2	Art. 32	● ALTA
P1.8	¿Se asigna %presupuesto mínimo (recomendado 5-10% OPEX TI)?	Med. 1	Anexo I.6	8.1	Art. 32	● MEDIA

MAPEO SECCIÓN 2: GESTIÓN DE ACTIVOS Y INVENTARIO

Tabla 2.1: Preguntas Activos → Requisitos Normativos

# Pregunta	Pregunta Encuesta	NIS2	CRA	ISO 27001	GDPR	Criticidad
P2.1	¿Existe inventario formalizado de todos los activos de información?	Med. 3	Anexo I	5.9	Art. 5, 32	● CRÍTICA
P2.2	¿Se clasifica cada activo según criticidad (crítico/alto/medio/bajo)?	Med. 3	Anexo I	5.9	Art. 5, 32	● CRÍTICA
P2.3	¿Se identifica propietario responsable (owner) de cada activo?	Med. 3	Anexo I	5.9	Art. 5, 32	● CRÍTICA
P2.4	¿Se monitorea cambio de estado (creación, modificación, eliminación)?	Med. 3	Anexo I.4	8.2	Art. 32	● ALTA
P2.5	¿Se audita acceso a activos críticos (logs + revisión Q)?	Med. 3	Anexo I.7	8.3	Art. 32	● ALTA

Tabla 2.2: Preguntas Datos Personales (GDPR)

# Pregunta	Pregunta Encuesta	GDPR	Criticidad
P2.6	¿Se identifica dónde se procesan datos personales?	Art. 5, 28	● CRÍTICA
P2.7	¿Existe registro de actividades tratamiento (RoPA)?	Art. 30	● CRÍTICA
P2.8	¿Se han realizado DPIA para tratamientos de riesgo alto?	Art. 35	● ALTA

MAPEO SECCIÓN 3: VULNERABILIDADES Y GESTIÓN DE RIESGOS

Tabla 3.1: Preguntas Vulnerabilidades → NIS2/CRA

# Pregunta	Pregunta Encuesta	NIS2	CRA	ISO 27001	Criticidad
P3.1	¿Se ejecuta escaneo de vulnerabilidad es al menos mensualmente?	Med. 3	Anexo I.4	12.6	● CRÍTICA
P3.2	¿Se clasifica vulnerabilidad por CVSS v4.0 (scores: crítico 9.0+)?	Med. 9	Anexo I.5	12.6	● CRÍTICA
P3.3	¿Se remedia vulnerabilidad crítica en <7 días?	Med. 3	Anexo I.4	8.2	● CRÍTICA
P3.4	¿Se rastrean vulnerabilidad es conocidas de terceros (SBOM)?	Med. 7	Anexo I.7	15.1	● ALTA
P3.5	¿Se realiza análisis SCA (componentes /dependencias) automáticamente?	Med. 2	Anexo I.4	14.2	● ALTA

NIS2 Med. 3 Requisito: Respuestas SÍ en P3.1, P3.2, P3.3 son **mandatorias** para operador esencial.

Tabla 3.2: Preguntas Gestión de Riesgos

# Pregunta	Pregunta Encuesta	NIS2	ISO 27001	Criticidad
P3.6	¿Se realiza análisis de riesgos anualmente?	Med. 1	12.6	● CRÍTICA
P3.7	¿Se documenta matriz de riesgos con scores (probabilidad × impacto)?	Med. 1	12.6	● CRÍTICA
P3.8	¿Se definen controles mitigadores para riesgos residuales ≥ medio?	Med. 1	8.2	● ALTA

MAPEO SECCIÓN 4: PRUEBAS DE SEGURIDAD (TESTING)

Tabla 4.1: Preguntas Testing → NIS2/OWASP

# Pregunta	Pregunta Encuesta	NIS2	ISO 27001	OWASP	Criticidad
P4.1	¿Se realiza análisis SAST (static) en 100% código?	Med. 2	14.2	TOP 10	● ALTA
P4.2	¿Se realiza análisis DAST (dynamic) antes producción?	Med. 2	14.2	TOP 10	● ALTA
P4.3	¿Se ejecuta prueba de penetración al menos anualmente?	Med. 9	14.2	OSSTMM	● ALTA
P4.4	¿Se realizan pruebas sobre APIs y cloud environments ?	Med. 2	14.2	API Top 10	● MEDIA
P4.5	¿Se documentan hallazgos y se rastrea remediación?	Med. 9	8.2	Governance	● ALTA

MAPEO SECCIÓN 5: SIEM Y DETECCIÓN

Tabla 5.1: Preguntas SIEM → NIS2 Med. 8

# Pregunta	Pregunta Encuesta	NIS2	ISO 27001	Criticidad
P5.1	¿Existe SIEM (centralizador logs) operativo 24/7?	Med. 8	8.4	● CRÍTICA
P5.2	¿Se retienen logs >90 días para análisis forense?	Med. 8	8.4	● ALTA
P5.3	¿Se generan alertas automáticas para eventos críticos?	Med. 8	8.4	● CRÍTICA
P5.4	¿Se realiza tuning mensual de alertas (reducir ruido)?	Med. 9	8.4	● MEDIA
P5.5	¿Existe SOC (Security Operations Center) dedicado?	Med. 8	16.1	● ALTA

NIS2 Med. 8 Requisito: P5.1, P5.2, P5.3 son **mandatarias** para operador esencial.

MAPEO SECCIÓN 6: RESPUESTA A INCIDENTES

Tabla 6.1: Preguntas IR → NIS2 Med. 8 / GDPR Art. 33

# Pregunta	Pregunta Encuesta	NIS2	GDPR	ISO 27001	Criticidad
P6.1	¿Existe plan formalizado de respuesta a incidentes?	Med. 8	Art. 33	16.1	● CRÍTICA
P6.2	¿Se identifican fases (detection – containment – eradication)?	Med. 8	Art. 33	16.1	● CRÍTICA
P6.3	¿Se define MTTD (mean time detect) objetivo <24h?	Med. 8	Art. 33	16.1	● CRÍTICA
P6.4	¿Se define MTTR (mean time recover) objetivo <48h?	Med. 8	Art. 33	16.1	● CRÍTICA
P6.5	¿Se ejecutan simulacros (tabletop) al menos semestralmente?	Med. 8	Art. 33	16.1	● ALTA
P6.6	¿Se notifica a autoridad en <72h si breach de datos?	Med. 8	Art. 33	16.1	● CRÍTICA
P6.7	¿Se comunica a afectados en <30 días si riesgo alto?	Med. 8	Art. 34	16.1	● CRÍTICA

GDPR Requisito Crítico: P6.6 y P6.7 son **legalmente mandatorias** en caso de breach.

MAPEO SECCIÓN 7: CAPACITACIÓN Y CONCIENCIACIÓN

Tabla 7.1: Preguntas Capacitación → NIS2/GDPR

# Pregunta	Pregunta Encuesta	NIS2	GDPR	ISO 27001	Criticidad
P7.1	¿Se realiza capacitación obligatoria anual en seguridad?	Med. 4	Art. 32	6.3	● ALTA
P7.2	¿Se incluye GDPR, phishing, ingeniería social en currículo?	Med. 4	Art. 32, 37	6.3	● ALTA
P7.3	¿Se mide engagement (quiz, simulaciones phishing)?	Med. 9	Art. 32	6.3	● MEDIA
P7.4	¿Se tienen roles especiales (DPO, security officers) capacitados?	Med. 1	Art. 37	5.3	● ALTA
P7.5	¿Se registra asistencia y completitud de capacitación?	Med. 4	Art. 32	6.3	● MEDIA

MAPEO SECCIÓN 8: CADENA DE SUMINISTRO (CRA/NIS2)

Tabla 8.1: Preguntas Supply Chain → CRA/NIS2 Med. 7

# Pregunta	Pregunta Encuesta	NIS2	CRA	ISO 27001	Criticidad
P8.1	¿Se identifica inventario de proveedores y terceros?	Med. 7	Anexo I	15.1	● CRÍTICA
P8.2	¿Se evalúan proveedores por madurez seguridad?	Med. 7	Anexo I.7	15.2	● ALTA
P8.3	¿Se incluye cláusulas seguridad en contratos?	Med. 7	Anexo I.7	15.2	● ALTA
P8.4	¿Se ejecutan auditorías de seguridad a proveedores críticos?	Med. 7	Anexo I.7	15.2	● ALTA
P8.5	¿Se gestionan APIs y integraciones de terceros?	Med. 7	Anexo I.4	15.1	● ALTA
P8.6	¿Se genera SBOM (Bill of Materials) de componentes?	Med. 7	Anexo I.5	15.1	● ALTA

CRA Requisito: Fabricantes digitales deben cumplir P8.1-P8.6 para productos IoT/software.

TABLA RESUMEN: TRAZABILIDAD COMPLETA

68 Preguntas → 4 Marcos Normativos

Framework	# Preguntas	Preguntas Críticas	Criticidad
NIS2	45+	P1.1-1.5, P2.1-2.5, P3.1-3.3, P5.1-5.3, P6.1-6.7, P8.1-8.6	● Mandatoria
CRA	15+	P1.5, P2.1, P3.4-3.5, P4.1-4.3, P8.1-8.6	● Mandatoria
ISO 27001	40+	P1.1-1.2, P2.1-2.3, P3.1-3.3, P5.1-5.3, P6.1-6.7	● Altamente recomendada
GDPR	25+	P2.6-2.8, P6.6-6.7	● Mandatoria

MATRIZ DECISIÓN: CUMPLIMIENTO POR NIVEL

Para Operador Esencial (NIS2)

Nivel de Cumplimiento: Todas preguntas CRÍTICAS (●) deben ser SÍ

Cumplimiento Total: SÍ en 100% de preguntas críticas =  NIS2 COMPLIANT
Cumplimiento Parcial: SÍ en 70-99% =  Brecha menor (<30 días remediación)
No Cumplimiento: SÍ en <70% =  Brecha mayor (requiere plan corrector)

CONCLUSIÓN

Esta matriz de mapeo asegura que:

-  Cada pregunta de la encuesta conecta a requisito regulatorio específico
-  NIS2 Medidas 1-9 están cubiertas (100% para operador esencial)
-  CRA Anexo I requisitos están cubiertos (para fabricantes digitales)
-  GDPR Artículos 5, 25, 28, 32-34 están cubiertos
-  ISO 27001:2022 controles están mapeados

Resultado: Implementar encuesta = Validación regulatoria España 2026

FIN DEL MAPEO DETALLADO